PROJECT : myproject

ร้านผัดกะเพรารวมมิตร

“อร่อยเกินเบอร์”

System Structure Summary — User Model ER Diagram & Login/Register Flow

หัวข้อภายในเอกสาร

1. ภาพรวมระบบและเทคโนโลยีที่ใช้
2. โครงสร้างโฟลเดอร์โปรเจค (Project Structure)
3. ER Diagram ของ User model และโมเดลที่เกี่ยวข้อง
4. Flow การสมัครสมาชิก (Register)
5. Flow การเข้าสู่ระบบ (Login) และหน้า Protected (เข้าสู่ระบบแล้วเท่านั้น)
6. Flow การออกจากระบบ (Logout)
7. การสาธิตขั้นตอนการใช้งานจริง (Demonstration)

จัดทำขึ้นสำหรับโปรเจคการศึกษา ระบบจัดการเมนูอาหาร + ระบบสั่งอาหาร (Order/Delivery) พัฒนาโดย นักศึกษา KPRU · 7 กันยายน 2569

1. ภาพรวมระบบ

โปรเจค myproject เป็นเว็บแอปพลิเคชัน Django สำหรับร้านอาหาร "ผัดกะเพารวมมิตร" ประกอบด้วย ระบบจัดการเมนู (CRUD), ระบบสั่งอาหารตามโต๊ะ, ระบบเดลิเวอรี่, การชำระเงิน, ใบเสร็จ, Dashboard พร้อมกราฟ, ส่งออกรายงาน (CSV/Excel), QR Code ประจำโต๊ะ, REST API และระบบสมาชิก/ผู้ใช้ฝ่ายขาย (Authentication: สมัครสมาชิก – เข้าสู่ระบบ – หน้าเฉพาะสมาชิก – ออกจากระบบ)

User model เป็นโมเดลมาตรฐานของ Django (django.contrib.auth.models.User) ซึ่งระบบนี้ใช้ร่วมกับโมเดล Profile (เก็บรูปโปรไฟล์/สถานะสมาชิก) และผูกกับ Order ผ่าน foreign key created_by เพื่อให้แต่ละหน้าสืบทอดสิทธิ์ตามสถานะผู้ใช้ (เข้าสู่ระบบแล้ว / เป็น Staff / เป็นผู้ดูแล)

เทคโนโลยี (Technology Stack)

ส่วน	เทคโนโลยี
ภาษาหลัก / Framework	Python 3.14, Django 6.0.6
ฐานข้อมูล	SQLite (db.sqlite3) รองรับการย้ายเป็น PostgreSQL ได้
Authentication	django.contrib.auth (User, Session, Password hashing PBKDF2, CSRF token)
Frontend	Bootstrap 5.3, Chart.js, Leaflet.js (แผนที่), QR Code
API	Django REST Framework (Session/Basic Authentication)
Deploy	Docker / docker-compose, gunicorn

URL หลักของระบบ

URL	หน้า / ฟังก์ชัน	สิทธิ์	
/register/	สมัครสมาชิก (ต้องตอบแคปต์ชา, รอผู้ดูแลอนุมัติ)	ทุกคน	
/login/	เข้าสู่ระบบ	ทุกคน	
/logout/	ออกจากระบบ	ผู้ใช้ที่ login แล้ว	
/	/menu/	หน้าหลัก และ รายการเมนู (อ่านได้ทุกคน)	ทุกคน
/orders/	เปิดออเดอร์ใหม่ + รายการออเดอร์	login_required	
/orders//	จัดการออเดอร์ (เพิ่ม/ลดรายการ, ข้อมูลจัดส่ง)	login_required	
/profile/, /my-orders/	โปรไฟล์ และ ประวัติสั่งอาหารของตัวเอง	login_required	
/dashboard/, /delivery/	Dashboard สถิติ และ จัดการเดลิเวอรี่	staff_required	
/users/, /menu/add/, /categories/	จัดการผู้ใช้ / เมนู / หมวดหมู่	staff_required	
/admin/	Django Admin	is_superuser	

2. โครงสร้างโฟลเดอร์โปรเจค (Project Structure)

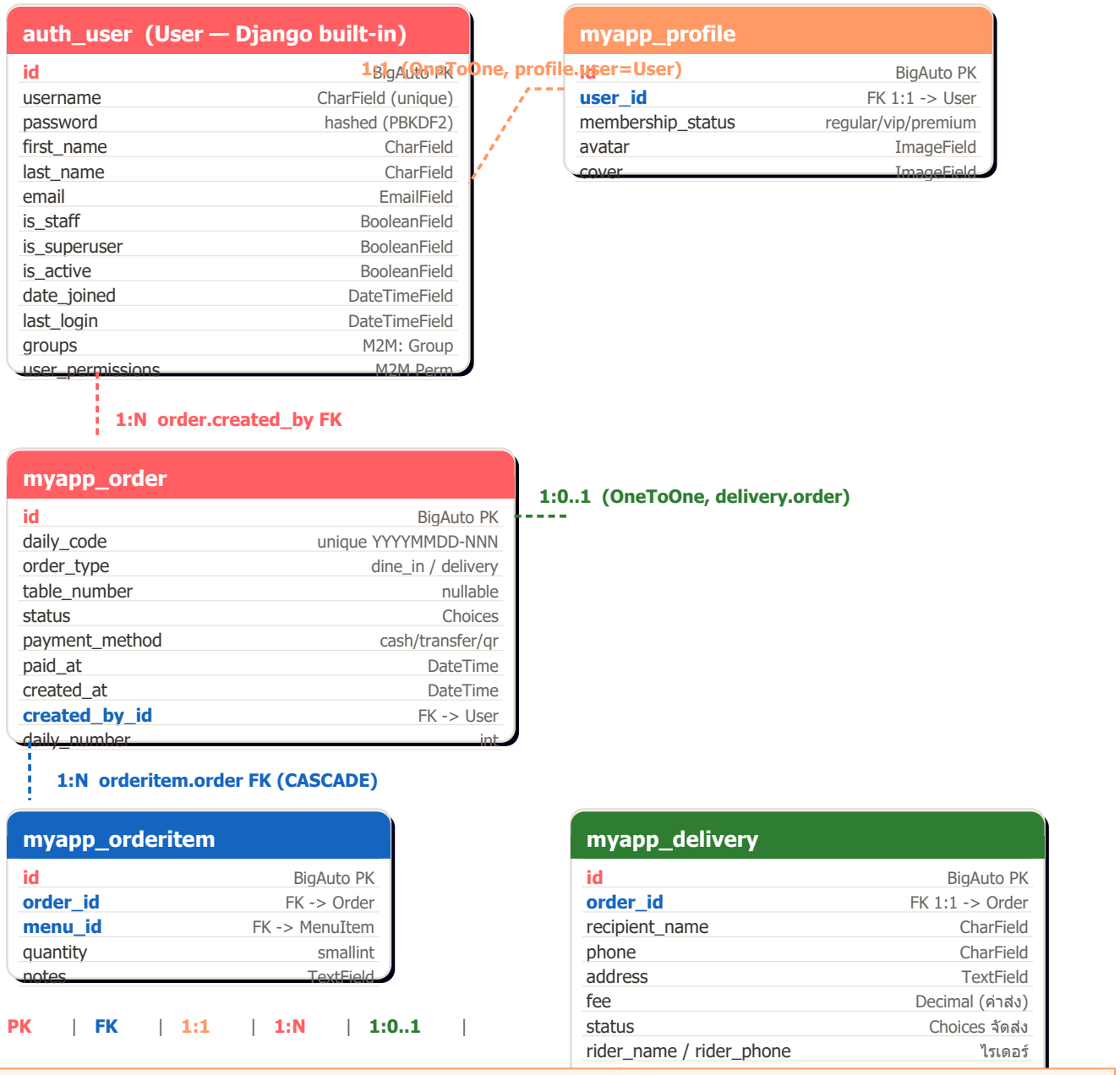
myproject/ │ manage.py ..... คำสั่งหลัก (runserver / migrate / test) │ requirements.txt ..... รายการ packages │ Dockerfile, docker-compose.yml .. สำหรับ Deploy │ db.sqlite3 ..... ฐานข้อมูล SQLite │ media/ ..... รูปภาพที่อัปโหลด (เมนู/avatar) │ ├── myproject/ ..... โฟลเดอร์โครงตั้งค่า (Project) │ settings.py ..... ค่ากำหนด (AUTH, TIME_ZONE, DRF...) │ urls.py ..... ทางเข้า URL หลัก (/admin/ + รวม myapp.urls) │ sitemaps.py ..... SEO sitemap │ └── myapp/ ..... แอปหลักของระบบ models.py ..... โมเดลข้อมูล (Menu, Order, Delivery, Profile...) views.py ..... ตรรกะหน้าเว็บ + authentication flow ทั้งหมด urls.py ..... เส้นทาง URL ของแอป forms.py . ..... ฟอร์ม (UserRegisterForm, OrderForm, DeliveryForm...) admin.py ..... ลงทะเบียนโมเดลใน /admin/ api.py . ..... DRF Serializer + ViewSet (/api/...) context_processors.py ..... สถิติแจ้งเตือนใส่ navbar (badge) management/commands/ seed_menu.py ..... คำสั่งสร้างเมนูตัวอย่าง migrations/ ..... 0016 ไฟล์ (ฐานข้อมูล) templates/ . ..... HTML: basetemplate, login, register, order_*, dashboard... tests.py ..... 27 test cases

จุดที่เกี่ยวข้องกับ Authentication โดยตรง (ในโค้ด)

ไฟล์	ส่วนที่รับผิดชอบ
myapp/views.py	login_view, logout_view, register_view, staff_required, decorator @login_required/@staff_required
myapp/forms.py	UserRegisterForm (captcha, is_active=False), UserCreateForm/UserUpdateForm (สำหรับ Staff), UserChangePasswordForm
myapp/models.py	User (built-in) + Profile (OneToOne) + Order.created_by FK
myapp/urls.py	route: /register/ /login/ /logout/ /profile/ /my-orders/ /users/ ...
myproject/settings.py	LOGIN_URL='login', LOGIN_REDIRECT_URL='home', SessionMiddleware, CSRF
templates/login.html, register.html	หน้า UI ฝั่งผู้ใช้

3. ER Diagram — User model และโมเดลที่เกี่ยวข้อง

User เป็นโมเดลในตัวของ Django เก็บบัญชีผู้ใช้ทั้งหมด (พนักงาน+สมาชิก) ระบบนี้เพิ่ม Profile แบบ OneToOne เพื่อเก็บข้อมูลเสริม และผูก Order ผ่าน FK created_by เพื่อระบุว่าใครเป็นคนเปิดออเดอร์ โดยนโยบายสิทธิ์คือ is_active=False = ยืนยันตัวตนไม่ได้ (บัญชีสมัครใหม่ยังไม่ได้อนุมัติ), is_staff=True = เข้าใช้งาน Dashboard/จัดการระบบได้



หมายเหตุ: FK หมายถึง Foreign Key — auth_user.username ต้องไม่ซ้ำ และรหัสผ่านจะถูก hash (ไม่เก็บเป็นข้อความธรรมดา)
ค่าสังสร้างโมเดลอยู่ใน myapp/models.py และ migration ล่าสุดคือ 0016 (เพิ่ม Delivery + order_type)

4. Flow การสมัครสมาชิก (Register)

เมื่อผู้ใช้เข้า /register/ ระบบจะทำงานตามขั้นตอนด้านล่าง ความพิเศษคือ ต้องตอบแคปต์ชา และบัญชีใหม่จะยังใช้งานไม่ได้จนกว่าผู้ดูแล (Staff) จะอนุมัติ (is_active=True)

1 เปิดหน้า /register/ (GET)

Server สร้างโจทย์แคปต์ชาแบบบวกเลข (เช่น 4 + 7 = ?) เก็บคำตอบไว้ใน session 'register_captcha' แล้วส่งฟอร์มให้ผู้ใช้

GET /register/

2 กรอกข้อมูลสมัครสมาชิก

ชื่อผู้ใช้ (username), ชื่อจริง, นามสกุล, อีเมล, รหัสผ่าน 2 ครั้ง และคำตอบแคปต์ชา ฟอร์มจาก form UserRegisterForm

POST /register/

3 ตรวจสอบความถูกต้อง (Validation)

• ชื่อผู้ใช้ต้องไม่ซ้ำ (clean_username) • รหัสผ่านต้องตรงกันและผ่านนโยบายรหัสผ่านของ Django • คำตอบแคปต์ชาต้องถูกต้อง

ผ่าน ? ใช่ / ไม่ใช่

4 สร้างบัญชีผู้ใช้ใหม่ (Success)

สร้าง User ด้วย set_password (เข้ารหัส PBKDF2), ตั้งค่า is_active=False, is_staff=False, is_superuser=False พร้อมสร้าง Profile อัตโนมัติ ล้างแคปต์ชาใน session แล้ว redirect ไป /login/ พร้อมข้อความ 'รอผู้ดูแลอนุมัติ'

irect ไม่ส่งผล แสดง error + สร้างแคปต์ชาใหม่

5 ผู้ดูแล (Staff) อนุมัติบัญชี

Staff เข้าที่ /users/ (หรือ /admin/) กดแก้ไขผู้ใช้ แล้วเปิดใช้งานบัญชี (is_active=True) จากนั้นสมาชิกจึงเข้าสู่ระบบได้

ไฟล์ที่เกี่ยวข้อง: myapp/views.py → register_view(), myapp/forms.py → UserRegisterForm (clean_captcha_answer, save ที่ตั้ง is_active=False), templates/register.html

5. Flow การเข้าสู่ระบบ (Login) และหน้า Protected

หน้า /login/ ใช้ AuthenticationForm ของ Django รองรับพารามิเตอร์ next เพื่อกลับสู่หน้าที่ต้องการหลังล็อกอินสำเร็จ

1 เปิดหน้า /login/ (GET)

ถ้าเข้าสู่ระบบอยู่แล้ว → redirect ไปหน้าหลักโดยอัตโนมัติ ถ้ายังไม่ได้เข้าสู่ระบบ → แสดงฟอร์ม username + password

POST /login/

2 ตรวจสอบชื่อผู้ใช้/รหัสผ่าน (authenticate)

Django ตรวจสอบ user + password ที่ hash ไว้ ถ้า is_active=False (ยังไม่ได้รับการอนุมัติ) จะถือว่าไม่ผ่านเหมือนรหัสผิด (ป้องกันการเดา)

ผ่าน ? ใช่ / ไม่ใช่

3 สร้าง Session เข้าสู่ระบบ (Success)

เรียก login(request, user) → สร้าง session (เก็บ user_id + CSRF token) แล้วตรวจสอบพารามิเตอร์ next ด้วย url_has_allowed_host_and_scheme ป้องกัน open redirect → redirect ไป next หรือไปหน้าหลัก (/)

าน : แสดง error 'ชื่อผู้ใช้หรือรหัสผ่านไม่ถูกต้อง'

4 ไปยังหน้า protected (ต้องเข้าสู่ระบบ)

หน้า @login_required เช่น /orders/ /profile/ /my-orders/ ถ้ายังไม่ login จะถูก redirect ไป /login/?next=URL ต้นทาง เมื่อ login สำเร็จระบบจะพากลับไปยัง URL นั้นโดยอัตโนมัติ

ระดับสิทธิ์ (Role-based) ในระบบ

สิทธิ์	เข้าใช้งานได้	ตัวอย่างหน้า
Anonymous (ไม่ login)	ดูเมนู / หน้าสาธารณะ	/, /menu/, /login/, /register/
User (login แล้ว)	ทุกหน้าสาธารณะ + หน้าระบบสั่งอาหาร + โปรไฟล์ตัวเอง	/orders/, /profile/, /my-orders/
Staff (is_staff=True)	ทั้งหมดข้างต้น + Dashboard/จัดการระบบ/ผู้ใช้/เดลิเวอรี่	/dashboard/, /delivery/, /users/, /menu/add/
Superuser	ทั้งหมด + Django Admin	/admin/

เงื่อนไข: @login_required ต้องการแค่เข้าสู่ระบบแล้ว ส่วน @staff_required (ใน views.py) ต้องเป็น is_staff=True จึงผ่าน ไม่เช่นนั้น redirect ไป /login/ เช่นกัน

6. Flow การออกจากระบบ (Logout)

1 **กดปุ่ม 'ออกจากระบบ' ทีแถบเมนู**

ลิงก์ไปที URL /logout/ (GET)

2 **ล้าง Session (logout(request))**

Django ลบข้อมูล session ทิ้งหมด + ล้าง framework backend เพื่อให้ทุกหน้าเห็นว่า 'ไม่ได้ login' แล้ว

3 **แจ้งเตือนและกลับหน้า Login**

แสดงข้อความ 'ออกจากระบบเรียบร้อย' แล้ว redirect ไป /login/ จากนีเข้าหน้า /orders/ หรือ /profile/ จะถูกบังคับกลับมาล็อกอินอีกครัง

7. การสาธิตขั้นตอนการใช้งานจริง (Demonstration)

วิธีรันระบบ: 1) python manage.py migrate 2) python manage.py seed_menu (เมนูตัวอย่าง) 3) python manage.py createsuperuser (สร้างบัญชีพนักงาน) 4) python manage.py runserver แล้วเปิด http://127.0.0.1:8000/

ขั้นตอนที่ 1 — สมัครสมาชิก (Register)

1) เปิด /register/ → เห็นโจทย์แคปต์ชา "X + Y = ?" 2) กรอก username เช่น 'pong', อีเมล, รหัสผ่าน (ตามนโยบาย) และคำตอบ 3) กดสมัคร → ระบบสร้างบัญชีคือ is_active=False และแสดงข้อความ "รอผู้ดูแลอนุมัติ" 4) ยังไม่สามารถเข้าสู่ระบบได้

ขั้นตอนที่ 2 — Login (ก่อนอนุมัติ)

เปิด /login/ กรอก username/password → ระบบตรวจพบว่ายังไม่ผ่านการอนุมัติ จึงแสดง "ชื่อผู้ใช้หรือรหัสผ่านไม่ถูกต้อง" (ตามนโยบายความปลอดภัย)

ขั้นตอนที่ 3 — Staff อนุมัติบัญชี

Login ด้วยบัญชีแอดมิน/Staff → ไปที่ /users/ (จัดการผู้ใช้) → ค้นหา 'pong' → กดแก้ไข → ทำเครื่องหมาย "เปิดใช้งานบัญชี" (is_active=True) → บันทึก

ขั้นตอนที่ 4 — Login สำเร็จ + เข้าหน้า Protected

1) เปิด /orders/ (หน้าต้องเข้าสู่ระบบ) → ถูก redirect ไป /login/?next=/orders/ 2) login สำเร็จ → ระบบพากลับมาที่ /orders/ โดยอัตโนมัติ 3) เปิด /profile/ ดูโปรไฟล์ตัวเองได้ 4) ลองเปิด /dashboard/ → ไม่ใช่ Staff → ถูก redirect ไปหน้า Login อีกครั้ง (ตาม decorator staff_required)

ขั้นตอนที่ 5 — Logout

กด "ออกจากระบบ" ที่แถบเมนู → กลับไปหน้า /login/ → ลองเปิด /orders/ อีกครั้ง → ถูกบังคับกลับมาล็อกอิน (ยืนยันว่า session ถูกล้างแล้ว)

ขั้นตอน/การกระทำ	ผลลัพธ์ที่คาดหวัง
สมัครสมาชิกสำเร็จ	สร้างบัญชี (is_active=False), แจ้งรออนุมัติ, redirect ไป /login/
Login ก่อนอนุมัติ	แสดง error 'ชื่อผู้ใช้หรือรหัสผ่านไม่ถูกต้อง'
Staff อนุมัติ (is_active=True)	ผู้ใช้เข้าสู่ระบบได้
Login สำเร็จจาก /orders/ (next)	redirect กลับ /orders/ อัตโนมัติ
Login สำเร็จจากหน้า /login/ ตรง ๆ	redirect ไปหน้าหลัก /
เข้าหน้า /dashboard/ โดยไม่ใช่ Staff	redirect ไป /login/
Logout	ล้าง session → กลับ /login/ → หน้า protected ต้องล็อกอินใหม่